

Classification: Internal

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

Incident Response Policy

AIR-ISMS-POL-003 | Version 1.0 | May 2026

Document Control

Document ID	AIR-ISMS-POL-003
Version	1.0
Status	Approved
Classification	Internal
Document Owner	Head of Security & Compliance
Reviewed By	Head of IT Operations Head of Legal & Partnerships
Approved By	Chief Executive Officer
Approval Date	May 2026
Review Cycle	Annual / following any P1 or P2 incident
Next Review Due	May 2027
Related Documents	AIR-ISMS-POL-001 Information Security Policy AIR-ISMS-POL-002 Access Control Policy AIR-ISMS-RSK-002 Risk Register AIR-ISMS-AST-001 Asset Inventory
Applicable Standard	ISO/IEC 27001:2022 — Annex A Controls: 5.24, 5.25, 5.26, 5.27, 5.28, 6.8

1. Purpose

This policy establishes AIR's approach to managing information security incidents. It defines what constitutes an incident, how incidents are classified by severity, who is responsible for managing the response, and what obligations AIR has to notify affected parties, regulators, and government partners.

The goal of incident response is not only to contain and recover from security events, but to do so in a way that protects evidence, meets legal obligations, and produces lessons that strengthen AIR's security posture over time. A slow or disorganised response causes more harm than the incident itself.

2. Scope

This policy applies to all information security events and incidents affecting AIR systems, data, personnel, or partners, regardless of where the incident originates or which systems are involved. It covers:

- All systems within the ISMS scope (Azure, Microsoft 365, GitHub Enterprise, research repositories, managed endpoints)
- All personnel (employees, contractors, and research collaborators)
- Incidents involving third-party suppliers or partners where AIR data is affected
- Physical security incidents that result in or risk information compromise
- Near-misses (events that could have caused harm but did not)

Classification: Internal

3. Definitions

Term	Definition
Security Event	Any observable occurrence in a system or network that may indicate a policy violation, attempted attack, or anomalous behaviour. Not all events are incidents.
Security Incident	A security event that has been confirmed — or is sufficiently suspected — to have compromised the confidentiality, integrity, or availability of AIR information or systems.
Near-Miss	An event that had the potential to become an incident but did not cause harm, due to controls functioning correctly or chance. Near-misses are recorded and reviewed.
Personal Data Breach	An incident involving the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. Triggers GDPR notification obligations under Article 33.
Incident Lead	The individual assigned to coordinate AIR's response to a specific incident. Typically the Head of Security & Compliance, or a delegated deputy.
Incident Response Team (IRT)	The group convened to manage a specific incident. Composition varies by severity and incident type, but always includes the Incident Lead and IT Operations.

4. Incident Severity Classification

All incidents are assigned a severity level at the point of initial assessment. Severity determines response timeframes, escalation paths, and notification obligations. Classification may be revised as the incident is investigated.

Severity	Label	Description	AIR Examples
P1	Critical	Confirmed or highly probable breach of Restricted data. Active system compromise. Ransomware or destructive malware. Complete loss of a critical system. Requires immediate executive involvement.	Exfiltration of government-affiliated research data. Ransomware on Azure tenant. Compromise of a global administrator account. Active data destruction.
P2	High	Confirmed unauthorised access to AIR systems or Confidential data. Successful phishing resulting in credential compromise. Significant availability loss affecting research operations. Malware detected on a managed endpoint with Restricted data access.	Compromised employee account with access to research data. Malware on a laptop used for infrastructure analytics. Accidental external sharing of Confidential contract documents. Supplier breach affecting AIR data.
P3	Medium	Suspected breach under investigation. Confirmed policy violation involving data with potential exposure risk. Phishing email opened but no credentials entered. Anomalous account behaviour under review.	Contractor accessing data outside their authorised scope. Employee uploading Internal data to a personal cloud storage account. Suspicious login from an unfamiliar location. Shadow AI tool used to process Internal-classified research documents.
P4	Low	Confirmed policy violation with no data exposure risk. Failed attack attempt with no system access achieved. Suspicious activity investigated and ruled out. Near-miss with no material impact.	Phishing email reported and deleted before any interaction. Failed brute-force attempt blocked by Conditional Access. User attempting to access a system they are not authorised for — blocked. Lost device with no AIR data cached locally.

Classification: Internal

5. Incident Response Team

The Incident Response Team (IRT) is convened when an incident is confirmed or sufficiently suspected. Its composition is scaled to the severity of the incident.

Role	Responsibility	P1	P2	P3	P4
Incident Lead (Head of Security & Compliance)	Coordinates the overall response. Makes containment and escalation decisions. Owns communication to leadership and external parties.	✓	✓	✓	✓
IT Operations	Executes technical containment and recovery actions. Preserves logs and forensic artefacts. Implements access changes and system isolation.	✓	✓	✓	✓
Head of Legal & Partnerships	Advises on GDPR notification obligations, contractual duties to partners, and legal holds on evidence.	✓	✓	If personal data involved	—
Executive Leadership	Receives incident briefings. Approves major containment actions (e.g., system shutdown, partner notification). Acts as final decision authority.	✓	Briefed within 4 hours	—	—
Affected Department Head / Asset Owner	Provides context on affected systems and data. Supports business impact assessment. Assists with recovery prioritisation.	✓	✓	If relevant	—
External Support (forensics / legal counsel)	Engaged for complex incidents requiring specialist forensic capability or legal advice beyond internal capacity.	If required	If required	—	—

6. Incident Response Lifecycle

AIR's incident response follows six phases. Each phase has defined actions, owners, and outputs. No phase should be skipped, even for lower-severity incidents.

Phase 1 — Detection and Reporting

Any person who discovers or suspects a security incident must report it immediately to the Head of Security & Compliance via the designated reporting channel. The maximum acceptable delay between discovery and reporting is four hours. Earlier reporting is always preferred.

Reporting channels: Security incident email (security@airresearch.eu) | Direct call to Head of Security & Compliance | IT Operations helpdesk (for technical events).

Reporters should not attempt to investigate or remediate the issue themselves before reporting, this risks destroying evidence or spreading a compromise.

Phase 2 — Initial Assessment and Classification

The Incident Lead conducts an initial assessment within one hour of notification to determine whether the event constitutes a security incident and, if so, its severity.

Assessment considers: What systems and data are affected? Is the threat still active? Is Restricted or personal data involved? What is the potential scope of impact?

Classification: Internal

The incident is logged in the Incident Register with a unique ID (INC-YYYY-NNN), timestamp, initial classification, and assigned Incident Lead.

Phase 3 — Containment

Containment actions are taken to stop the incident from spreading or causing further harm. Containment is prioritised over full investigation.

Short-term containment (immediate): Isolate affected systems or accounts. Revoke compromised credentials. Block malicious traffic or IP addresses.

Long-term containment (within hours): Restore from clean backup if required. Implement temporary access restrictions. Deploy additional monitoring on affected systems.

All containment actions are documented with timestamps and the name of the person who performed them.

Phase 4 — Investigation and Evidence Preservation

With containment in place, the IRT investigates the root cause, scope, and impact of the incident. All evidence must be preserved before any remediation.

Evidence handling: Logs and forensic artefacts are collected and stored in PA-005 (Incident Investigation Evidence) with access restricted to the IRT. A chain-of-custody record is maintained for all evidence. Evidence must not be altered, deleted, or moved without Incident Lead approval.

The investigation must determine: How did the incident occur? What data or systems were accessed, modified, or exfiltrated? How long was the threat actor present? What controls failed or were absent?

Phase 5 — Eradication and Recovery

Once the root cause is understood, the threat is eradicated and affected systems are restored to a known-good state.

Eradication: Remove malware, close the attack vector, rotate all potentially compromised credentials, patch vulnerabilities that were exploited.

Recovery: Restore systems from verified clean backups. Confirm integrity of research data before resuming processing. Reintroduce systems to production only after a security validation check. Increase monitoring on recovered systems for a minimum of 30 days post-recovery.

Phase 6 — Post-Incident Review

Every confirmed security incident, regardless of severity, requires a post-incident review. The review is completed within 10 working days of incident closure.

The review must address: What happened and when? What went well in the response? What could have been detected or contained earlier? What control gaps were revealed? What changes to policies, procedures, or systems are required?

Outputs: A completed Post-Incident Review report (filed with PA-005). Any new or updated risks added to the Risk Register. Any policy or procedure updates actioned within an agreed timeframe. Lessons shared with relevant staff without disclosing sensitive investigation detail.

Classification: Internal

7. Response Timeframes

The following timeframes are mandatory. The clock starts from the moment the incident is reported to the Incident Lead, not from when it is formally classified.

Severity	Initial Response	Containment Target	Executive Briefing	Incident Closure Target
P1 — Critical	Within 1 hour	Within 4 hours	Immediate	72 hours (or as soon as resolved)
P2 — High	Within 4 hours	Within 24 hours	Within 4 hours	5 working days
P3 — Medium	Within 24 hours	Within 48 hours	If data breach risk	10 working days
P4 — Low	Within 72 hours	As required	Not required	15 working days

8. Notification Obligations

AIR has legal and contractual obligations to notify certain parties following specific types of incident. These obligations are time-critical and must be managed in parallel with technical response.

8.1 GDPR — Supervisory Authority Notification

Where an incident involves a personal data breach, AIR must notify the relevant data protection supervisory authority within 72 hours of becoming aware of the breach, unless the breach is unlikely to result in a risk to individuals' rights and freedoms (GDPR Article 33). The Head of Legal & Partnerships is responsible for making this determination and submitting the notification. The 72-hour clock starts from the moment AIR has sufficient awareness of the breach, not from the time it is fully investigated.

AIR's primary supervisory authority is the Spanish Data Protection Agency (AEPD), given the location of AIR's headquarters in Madrid. Where the breach affects individuals in other EU member states, the relevant lead supervisory authority must be identified in consultation with Legal & Partnerships.

8.2 GDPR — Individual Notification

Where a personal data breach is likely to result in a high risk to individuals' rights and freedoms, those individuals must be notified without undue delay (GDPR Article 34). The Head of Legal & Partnerships determines whether this threshold is met and drafts the notification in plain language. Notification must describe the nature of the breach, its likely consequences, and the measures taken or proposed.

8.3 Government Partner Notification

Where an incident involves or may involve government-affiliated research data (PA-001) or critical infrastructure analysis datasets (PA-002), AIR must notify the relevant government partner in accordance with the terms of the applicable data sharing agreement or research contract.

- The Incident Lead reviews applicable contracts to determine notification obligations and timeframes at the point of incident classification
- Government partner notification is coordinated by the Head of Legal & Partnerships
- No public statement about an incident involving government-affiliated data may be made without explicit approval from the relevant partner and AIR Executive Leadership

8.4 Internal Communication

Internal communication during an incident must be carefully managed to avoid speculation, unnecessary alarm, or premature disclosure.

Classification: Internal

- Incident information is shared on a strict need-to-know basis within the IRT
- All-staff communication is authorised by Executive Leadership and drafted by the Head of Legal & Partnerships in coordination with the Incident Lead
- Incident details must not be shared via personal devices, personal email, or any channel that may itself be compromised
- If the AIR communication systems are suspected to be compromised, out-of-band communication (personal mobile phones, in-person) must be used for IRT coordination

9. Evidence Handling

Evidence collected during an incident investigation must be handled in a way that preserves its integrity and admissibility. The following requirements apply to all incident evidence, stored as PA-005 (Incident Investigation Evidence).

- Evidence must be collected before any remediation action that could alter or destroy it
- All evidence is stored in a dedicated, access-controlled location, separate from operational systems. Access is restricted to the Incident Lead and IT Operations
- A chain-of-custody log is maintained for all evidence items, recording who collected the evidence, when, from which system, and all subsequent access to it
- Log files and forensic images must not be modified. Original copies are preserved; analysis is conducted on copies only
- Evidence must be retained for a minimum of one year following incident closure, or longer if legal proceedings are anticipated
- Evidence destruction requires written approval from the Head of Security & Compliance and the Head of Legal & Partnerships

10. Incident Register

All security events and incidents, including near-misses, are recorded in the AIR Incident Register. Each entry includes:

Field	Description
Incident ID	Unique identifier in format INC-YYYY-NNN (e.g. INC-2025-001)
Date/Time Reported	When the incident was first reported to the Incident Lead
Date/Time Detected	When the incident first occurred or was first detected (if known)
Reported By	Name and role of the person who first reported the incident
Severity	P1 / P2 / P3 / P4 — may be revised as investigation progresses
Incident Type	Category: data breach, malware, unauthorised access, policy violation, etc.
Systems Affected	Specific assets from the Asset Inventory (AIR-ISMS-AST-001)
Description	Factual summary of what occurred, without speculation
Containment Actions	Actions taken to limit the incident, with timestamps
Notification Status	GDPR notified? Partner notified? Date and reference number
Root Cause	Determined following investigation — left blank until confirmed
Residual Risk	Any new or updated risk register entries arising from this incident
Status	Open / Contained / Closed
Post-Incident Review	Date completed and reference to PIR document

Classification: Internal

11. Incident Reporting — All Personnel

If you discover or suspect an information security incident, report it immediately. Do not investigate it yourself. Do not discuss it with colleagues who are not directly involved. Do not attempt to fix it before reporting. Contact the Head of Security & Compliance or IT Operations immediately using the channels below.

Reporting Channel	Contact	When to Use
Security Incident Email	security@airresearch.eu	All incidents, use as the primary written record. Available 24/7.
Head of Security & Compliance (direct)	Direct call or Teams message	P1 and P2 incidents, or when you need immediate guidance.
IT Operations Helpdesk	it-support@airresearch.eu / internal extension	Technical events, malware alerts, suspicious system behaviour, account lockouts following a suspected attack.
Out-of-Band (personal mobile)	Contact details held in the Incident Response Contact List (held offline by IRT members)	When AIR communication systems may be compromised. P1 only.

AIR will not penalise any person who reports a genuine security concern in good faith, even if the concern turns out not to be an incident. Late or non-reporting is treated as a policy violation.

12. Non-Compliance

Failure to report a suspected or confirmed incident within the required timeframe, deliberate destruction or alteration of incident evidence, or unauthorised disclosure of incident details are serious policy violations. Such violations may result in disciplinary action, termination of employment or contract, and, where evidence is tampered with, potential legal liability. These obligations apply equally to employees and contractors.

13. Review and Maintenance

This policy is reviewed annually by the Head of Security & Compliance and approved by the Chief Executive Officer. It is also reviewed immediately following any P1 or P2 incident, or any incident that reveals a gap in this policy.

The Head of Security & Compliance is responsible for ensuring that lessons from post-incident reviews are incorporated into updates to this policy and related procedures within 30 days of the review being completed.

Role	Name	Signature	Date
Document Owner	Head of Security & Compliance		May 2026
Executive Approver	Chief Executive Officer		May 2026